

Architektura zálohování a ochrany dat aplikace Tappka

Návrh třívrstvého modelu ochrany dat

Podklad pro jednání o alokaci serverových kapacit

Verze dokumentu	1.0
Datum	31. 8. 2026
Zpracoval:a	Vývojový tým Tappka
Určeno	Vedení školy, IT oddělení, oddělení PEVKA
Stav	Návrh k projednání

Všechna technická tvrzení o platformě Supabase v tomto dokumentu jsou doložena odkazy na oficiální dokumentaci v kapitole D (Zdroje).

Obsah

1	Shrnutí pro vedení	2
2	Kontext a rozsah	3
2.1	Jaká data Tappka spravuje	3
2.2	Dva nezávislé systémy uložení	3
2.3	Kde jsou data fyzicky uložena	4
3	Analýza rizik	5
3.1	Odborný rámec: pravidlo 3–2–1	5
4	Vrstva 1 — ochrana na platformě Supabase Pro	6
4.1	Automatické denní zálohy	6
4.2	Co zálohy Supabase nepokrývají	6
4.3	Bezpečnostní opatření platformy	6
4.4	Co tarif Pro neobsahuje	7
4.5	Model sdílené odpovědnosti	7
5	Vrstva 2 — nezávislá záloha na serveru školy	9
5.1	Cíl	9
5.2	Architektura	9
5.3	Co přesně se zálohuje	9
5.4	Frekvence a retenční plán	10
5.5	Kalkulace potřebné kapacity	10
5.6	Zabezpečení záloh	11
5.7	Monitoring a ověřování obnovitelnosti	11
5.8	Proces vyžádání dat	12
5.9	Souhrn požadavků na školu	13
6	Vrstva 3 — lidsky čitelné exporty (koncept)	14
6.1	Myšlenka	14
6.2	Jaké situace by řešil	14
7	Souhrnné srovnání vrstev	15
8	Doporučený postup	15
A	Příloha: Konfigurace služby	17
A.1	Definice služby (docker-compose.yml)	17
A.2	Tajemství (/etc/tappka/backup.env, práva 0600)	17
A.3	Zálohovací skript (zkráceně)	17
B	Příloha: Manuál spuštění	18
C	Příloha: Postup obnovy	18
D	Zdroje	20

1 Shrnutí pro vedení

Tappka je webová aplikace, ve které vzniká a je uložena podstatná část studijních a reflektivních záznamů studujících. Ztráta těchto dat by nebyla obnovitelná z jiného zdroje — neexistuje papírová ani jiná paralelní evidence.

Aplikace dnes běží na platformě **Supabase** v tarifu **Pro**. Tento tarif zahrnuje automatické denní zálohy databáze s retencí sedmi dní. To je solidní základ, ale jako celková ochrana dat **nestačí**, a to ze tří konkrétních důvodů:

1. **Zálohy Supabase nezahrnují nahrané soubory.** Zálohuje se pouze databáze. Fotografie, profilové obrázky a nahrané dokumenty leží v odděleném úložišti, které automatické zálohy *nepokrývají vůbec*. Smazaný soubor je nenávratně ztracen i v tarifu Pro (viz kap. 4.2).
2. **Sedm dní je krátká lhůta.** Problém zjištěný po prázdninách, po zkouškovém období nebo po delší nepřítomnosti vyučující:ho už není z čeho obnovit.
3. **Všechny kopie leží u jednoho dodavatele.** Zálohy Supabase jsou uloženy v téže infrastruktuře jako produkční data. Nechrání proti výpadku, ukončení služby ani ztrátě přístupu k účtu.

Co navrhujeme

Doplnit stávající ochranu o **dvě nezávislé vrstvy**, které společně tvoří třívrstvý model:

Vrstva 1	Platformní ochrana Supabase Pro — denní zálohy databáze, retence 7 dní. Již funguje, beze změny nákladů.
Vrstva 2	<i>Nezávislá záloha na serveru školy.</i> Kontejnerizovaná služba, která jednou týdně stáhne kompletní kopii databáze <i>i všech nahraných souborů</i> a uloží ji šifrovaně na školní úložiště. Toto je hlavní předmět tohoto dokumentu.
Vrstva 3	Lidsky čitelné exporty — vize do budoucna. Data v podobě, kterou lze otevřít a přečíst i bez Tappky a bez technických znalostí.

O co konkrétně žádáme školu

Položka	Specifikace
Výpočetní kapacita	Virtuální server, Linux (Debian 12 nebo Ubuntu 24.04 LTS), 2 vCPU, 4 GB RAM
Diskový prostor	1 TB dedikovaného prostoru (odůvodnění kalkulací v kap. 5.5)
Software	Docker Engine s pluginem Docker Compose
Sít	Odchozí HTTPS (TCP 443) a TCP 5432 na infrastrukturu Supabase
Provozní součinnost	Předání zálohy na vyžádání v dohodnutých lhůtách (kap. 5.8)

Řešení je navrženo tak, aby po jednorázovém uvedení do provozu **nevyžadovalo průběžnou správu** — běží automaticky a upozorní pouze v případě selhání.

2 Kontext a rozsah

2.1 Jaká data Tappka spravuje

Z pohledu zálohování je podstatné, že data Tappky nejsou homogenní. Dělí se do kategorií, které se liší mírou nenahraditelnosti:

Kategorie	Příklad obsahu	Nahraditelnost
Autorský obsah studujících	Eseje, reflexe, sebehodnocení, roční týmové reflexe	Nenahraditelné
Hodnocení a zpětná vazba	Komentáře koučů:ek, výsledky, bodové zisky	Nenahraditelné
Procesní záznamy	Rezervace, docházka na aktivity, výpůjčky knih	Obtížně rekonstruovatelné
Nahrané soubory	Profilové fotografie, dokumenty, obrázky v esejích	Nenahraditelné
Konfigurace a číselníky	Týmy, role, tagy, kategorie, nastavení	Rekonstruovatelné

Většina objemu dat připadá na poslední dvě kategorie, ale *většina hodnoty* na první tři. Zálohovací strategie proto musí pokrýt obojí — nestačí zálohovat jen to, co zabírá místo.

2.2 Dva nezávislé systémy uložení

Klíčový fakt, na kterém stojí celý zbytek dokumentu: **Tappka ukládá data do dvou technicky oddělených systémů.**

Systém	Co obsahuje	Technologie
Databáze	Texty, hodnocení, vztahy, metadata	PostgreSQL
Úložiště souborů	Binární soubory — fotografie, dokumenty, obrázky	Objektové úložiště kompatibilní s S3, spravované samostatnou službou

Aplikace používá tři oddělené kontejnery (*buckety*) v úložišti souborů:

- **avatars** — profilové obrázky osob a týmů (veřejně čitelné)
- **images** — obálky knih a obrázky vložené do esejí (veřejně čitelné)
- **documents** — nahrané dokumenty (neveřejné, přístupné jen přes dočasné podepsané odkazy)

V databázi jsou o těchto souborech uloženy pouze *odkazy a metadata* — název, velikost, kdo soubor nahrál. Samotný obsah souboru v databázi není. Tento rozdíl je příčinou nejzávažnější mezery v současné ochraně, popsané v kapitole 4.2.

2.3 Kde jsou data fyzicky uložena

Parametr	Hodnota
Region	Central Europe (Zurich)
Označení regionu	<code>eu-central-2</code>
Stát	Švýcarská konfederace
Poskytovatel infrastruktury	Amazon Web Services (Supabase provozuje na AWS)
Výpočetní instance	<code>t4g.micro</code> (tarif Micro: 2 jádra ARM, 1 GB RAM, limit 60 souběžných připojení)
Zálohy	Uloženy v téže infrastruktuře a témže regionu jako produkční databáze

Právní kontext přenosu dat mimo EU

Švýcarsko není členem Evropské unie ani EHP. Přenos osobních údajů do Švýcarska je nicméně z pohledu GDPR postaven na roveň přenosu uvnitř EU: Evropská komise dne **15. 1. 2024** potvrdila, že Švýcarsko nadále zajišťuje odpovídající úroveň ochrany osobních údajů. Osobní údaje lze tedy z EU do Švýcarska předávat **bez nutnosti dalších záruk** (standardních smluvních doložek apod.) — viz zdroj [8].

Volba curyšského regionu je z hlediska ochrany dat příznivá: data neopouštějí evropský prostor a zůstávají geograficky blízko uživatel:ek.

Dopad na návrh vrstvy 2

Skutečnost, že produkční data i jejich zálohy leží v jednom regionu u jednoho poskytovatele, je hlavní argument pro vrstvu 2. Záloha uložená vedle originálu nechrání proti výpadku poskytovatele, ztrátě přístupu k účtu ani ukončení služby. Umístění kopie **na serveru školy v České republice** vytváří skutečnou geografickou i organizační nezávislost.

3 Analýza rizik

Zálohování není samoučelné — chrání proti konkrétním scénářům. Následující tabulka je zároveň odůvodněním, proč jedna vrstva nestačí.

Scénář	Vrstva 1	Vrstva 2	Vrstva 3
	Supabase	školní server	exporty
Omylem smazaný záznam, zjištěno do 7 dní	✓	✓	●
Omylem smazaný nebo přepsaný soubor	✗	✓	✓
Chyba v migraci, poškození struktury databáze	✓	✓	✗
Problém zjištěný po více než 7 dnech	✗	✓	✓
Kompromitace účtu, hromadné smazání dat	●	✓	✓
Delší výpadek platformy Supabase	✗	✓	✓
Ukončení služby Supabase nebo sporu s dodavatelem	✗	✓	✓
Ukončení provozu aplikace Tappka	✗	●	✓
Potřeba dat pro osobu bez technických znalostí	✗	✗	✓
Selhání či ztráta školního serveru	✓	✗	●

✓ pokrývá ● pokrývá částečně ✗ nepokrývá

Poslední řádek je záměrný: vrstvy se navzájem jistí. Neexistuje jediná událost, která by při zavedení všech tří vrstev vedla ke ztrátě dat.

3.1 Odborný rámec: pravidlo 3–2–1

Navržená architektura odpovídá pravidlu **3–2–1**, které jako základní standard ochrany dat doporučují americká agentura CISA i institut NIST [9]:

Požadavek	Naplnění v návrhu
3 kopie dat	Produkční data (Supabase) + zálohy Supabase + kopie na školním serveru
2 různá média	Spravovaná cloudová infrastruktura AWS + diskové pole školy
1 kopie mimo lokalitu	Školní server v ČR, jiný poskytovatel, jiná organizace, jiný stát

Moderní rozšíření pravidla, **3–2–1–1–0**, přidává jednu neměnitelnou (immutable) kopii a *nulu chyb*, tedy pravidelně **ověřovanou** obnovu. Oba tyto prvky jsou v návrhu obsaženy — viz kapitoly 5.6 a 5.7.

4 Vrstva 1 — ochrana na platformě Supabase Pro

Tato vrstva je již v provozu a nevyžaduje žádnou akci ze strany školy. Je zde popsána proto, aby bylo zřejmé, *co přesně pokrývá a co nikoli*.

4.1 Automatické denní zálohy

Parametr	Hodnota
Frekvence	Jednou denně, automaticky
Retence	7 dní (posledních sedm denních záloh)
Typ zálohy	Fyzická záloha (snímek diskového svazku PostgreSQL)
Rozsah	Databáze PostgreSQL
Obnova	Samoobslužně z administračního rozhraní (<i>Database</i> → <i>Backups</i>) nebo přes API
Nejhorší možná ztráta dat (RPO)	Až 24 hodin
Doba obnovy (RTO)	Řádově desítky minut až hodiny podle velikosti databáze
Dostupnost aplikace při obnově	Nedostupná — projekt je po dobu obnovy odstaven

Zdroj: oficiální dokumentace Supabase [1] a ceník [2].

4.2 Co zálohy Supabase nepokrývají

Zásadní omezení: nahrané soubory nejsou zálohovány

Dokumentace Supabase uvádí doslova, že zálohy databáze *nezahrnují objekty uložené přes Storage API* — databáze o nich obsahuje pouze metadata [1].

Prakticky to znamená: pokud dojde ke smazání nebo poškození souboru v kontejnerech *avatars*, *images* nebo *documents*, **neexistuje žádná záloha, ze které by šel obnovit**. Denní zálohy obnoví pouze databázový záznam odkazující na soubor, který už neexistuje — výsledkem je nefunkční odkaz.

Toto omezení není vadou konkrétního tarifu. Vyplývá z toho, že zálohy jsou fyzické snímky diskového svazku databáze, zatímco soubory leží v samostatném objektovém úložišti mimo tento svazek. Omezení tedy platí ve všech tarifech.

Kromě souborů se zálohy netýkají:

- hesel vlastních databázových rolí (nejsou v denních zálohách obsažena),
- trvale smazaných objektů (*deleted objects cannot be recovered*),
- replikačních slotů a odběrů, které je nutné po obnově ručně obnovit.

4.3 Bezpečnostní opatření platformy

Tarif Pro poskytuje následující bezpečnostní prvky, které Tappka využívá nebo může využít:

Opatření	Popis	Stav
Zabezpečení na úrovni řádků (RLS)	Přístupová pravidla vynucovaná přímo databází, nikoli aplikací. Uživatel:ka nemůže obejít pravidla ani přímým dotazem na API.	✓zavedeno
Vynucení TLS (<i>SSL Enforcement</i>)	Odmítnutí nešifrovaných databázových spojení	doporučeno
Síťová omezení	Omezení přístupu k databázi na povolené rozsahy IP adres	doporučeno
Vícefaktorové ověření	Ochrana účtů se správcovským přístupem k projektu	✓zavedeno
Omezení četnosti požadavků	Ochrana přihlašování proti automatizovaným útokům	✓výchozí
Retence provozních záznamů	7 dní historie logů	součást tarifu
Šifrování přenosu	TLS mezi aplikací, databází i úložištěm souborů	✓výchozí

Zdroj: produkční kontrolní seznam Supabase [5] a ceník [2].

4.4 Co tarif Pro neobsahuje

Pro úplnost a korektnost podkladu je nutné uvést i to, co v tarifu Pro chybí:

- **Přístup k auditní zprávě SOC 2.** Společnost Supabase je jako organizace držitelem certifikace SOC 2 Type 2 a je každoročně auditována [4]. Samotnou auditní zprávu si však mohou stáhnout pouze zákazníci v tarifech Team a Enterprise. V tarifu Pro tedy *platforma je certifikovaná, ale doklad o tom není k dispozici*.
- **Certifikace ISO 27001 a smlouva o zpracování dle HIPAA** — nabízeny až ve vyšších tarifech.
- **Smluvní garance dostupnosti (SLA).** Tarif Pro zahrnuje e-mailovou podporu, nikoli závazek dostupnosti služby [2].
- **Jednotné přihlášení (SSO) pro správu organizace.**

Praktický dopad

Absence SLA znamená, že v případě výpadku Supabase **neexistuje smluvně vymahatelná lhůta obnovení služby**. Škola je odkázána na dobrou vůli dodavatele. Vrstva 2 tuto závislost odstraňuje: i při delším výpadku zůstávají data v držení školy a lze je použít.

4.5 Model sdílené odpovědnosti

Supabase publikuje explicitní model sdílené odpovědnosti [3]. Zjednodušeně:

Odpovědnost Supabase	Odpovědnost provozovatele aplikace
Provoz a zálohování databáze, údržba operačního systému, správa a monitoring infrastruktury	Návrh datového modelu, nastavení přístupových práv a RLS, správa tajemství, vlastní zálohovací strategie nad rámec platformy

Dokumentace to shrnuje větou, kterou je vhodné citovat: „*Supabase klade kolem vaší databáze jen velmi málo zábran. To vám dává velkou kontrolu, ale zároveň to znamená, že věci můžete rozbít.*“ [3] Odpovědnost za data tedy zůstává na straně provozovatele — a tím je v konečném důsledku škola.

5 Vrstva 2 — nezávislá záloha na serveru školy

Toto je jádro návrhu a hlavní důvod vzniku tohoto dokumentu.

5.1 Cíl

Vytvořit a automaticky udržovat **úplnou, samostatně použitelnou kopii** všech dat Tappky — databáze *i* nahraných souborů — na infrastruktuře, kterou vlastní a kontroluje škola, nezávisle na dodavateli.

5.2 Architektura

Řešení je navrženo jako jediná kontejnerizovaná služba spouštěná plánovačem **cron**. Kontejnerizace (Docker) je zvolena záměrně, ze tří důvodů:

1. **Nulové nároky na prostředí serveru.** Kontejner nese vlastní verze všech nástrojů. Škola neinstaluje PostgreSQL, Python ani nic dalšího — pouze Docker.
2. **Shoda verzí.** Nástroj `pg_dump` musí odpovídat verzi serveru PostgreSQL. Kontejner tuto shodu zaručuje a izoluje ji od aktualizací školního systému.
3. **Reprodukovatelnost a přenositelnost.** Stejný kontejner lze spustit na jiném stroji a ověřit obnovu, aniž by se cokoli měnilo v konfiguraci.

Průběh jednoho zálohovacího cyklu

#	Krok	Popis
1	Spuštění	cron v kontejneru spustí zálohovací skript (neděle 02:00)
2	Výpis databáze	Tři samostatné soubory: role, struktura, data
3	Kontrola	Ověření, že žádný z výpisů není prázdný; při chybě cyklus končí a upozorní
4	Synchronizace souborů	Přírůstkové stažení všech tří kontejnerů úložiště
5	Zabalení a šifrování	Komprese a zašifrování archivu veřejným klíčem
6	Kontrolní součet	Výpočet SHA-256 pro pozdější ověření neporušenosti
7	Údržba retence	Odstranění bodů obnovy nad rámec retenčního plánu
8	Signalizace	Potvrzení úspěchu monitoringu; při selhání e-mailové upozornění

5.3 Co přesně se zálohuje

Databáze

Výpis se pořizuje oficiálním nástrojem Supabase CLI, doporučeným postupem rozděleným do tří souborů [6]. Toto rozdělení umožňuje obnovit strukturu bez dat, data bez struktury nebo obojí — podle povahy havárie.

Soubor	Obsah	K čemu slouží
<code>roles.sql</code>	Databázové role a oprávnění	Obnova přístupových práv
<code>schema.sql</code>	Struktura tabulek, indexy, pravidla RLS, pohledy, funkce	Postavení prázdné, ale funkční kopie
<code>data.sql</code>	Vlastní obsah tabulek	Naplnění daty

Nahrané soubory

Úložiště souborů zpřístupňuje rozhraní kompatibilní s S3 [7], což umožňuje použít standardní nástroj `rclone`. Synchronizace je **přírůstková** — porovnává se kontrolní součet a přenášejí se pouze nové a změněné soubory. Druhý a každý další běh je proto řádově rychlejší a nezatěžuje datový přenos.

Toto je jediná ochrana nahraných souborů, která existuje

Vzhledem k omezení popsanému v kapitole 4.2 je tato část vrstvy 2 **jedinou** zálohou fotografií a dokumentů v celém systému. Pokud by se škola rozhodla vrstvu 2 nezavést, zůstanou nahrané soubory zcela bez zálohy.

5.4 Frekvence a retenční plán

Zálohovací cyklus běží **jednou týdně** pro databázi i soubory zároveň. Retence sleduje model *děd – otec – syn*, který drží hustou historii pro nedávné události a řídkou pro vzdálené:

Úroveň	Perioda	Pokrývá	Počet
Týdenní	každý týden	poslední dva měsíce	8
Měsíční	poslední v měsíci	poslední rok	12
Roční	poslední v roce	dlouhodobá archivace	3
Celkem bodů obnovy			23

Tento plán znamená, že problém lze odhalit a napravit i po měsících. Roční body obnovy zároveň umožňují doložit stav dat na konci každého akademického roku.

Poznámka k RPO vrstvy 2

Týdenní frekvence znamená, že vrstva 2 může ztratit až sedm dní práce. To je vědomý kompromis: vrstva 2 **není** první linií obrany — tou je vrstva 1 s denní frekvencí. Vrstva 2 řeší scénáře, které vrstva 1 nepokrývá vůbec (soubory, delší horizont, nezávislost na dodavateli), a pro ty je týdenní perioda dostatečná. Pokud by se v budoucnu ukázala jako nedostatečná, lze frekvenci zvýšit změnou jediného řádku konfigurace, bez zásahu do architektury.

5.5 Kalkulace potřebné kapacity

Tarif Pro zahrnuje 100 GB prostoru pro soubory a 8 GB diskového prostoru databáze (s možností navýšení) [2]. Kalkulace níže počítá s **plným vyčerpáním** zahrnutých kapacit, tedy s cílovým, nikoli současným stavem — aby alokace nebyla za rok znovu předmětem jednání.

Položka	Jednotka	Počet	Celkem
Aktuální zrcadlo souborů	100 GB	1	100 GB
Verzované změny souborů (5 %/měsíc, 12 měsíců)	5 GB	12	60 GB
Týdenní výpisy databáze (komprimované)	5 GB	8	40 GB
Měsíční výpisy databáze	5 GB	12	60 GB
Roční výpisy databáze	5 GB	3	15 GB
Pracovní prostor pro rozbalení a ověření obnovy	—	—	150 GB
Součet			425 GB
Rezerva na růst dat a prodloužení retence (přibližně 2×)			425 GB
Navrhovaná alokace			1 TB

Rezerva není nadsazená: zaručuje, že zálohovací systém nepřestane fungovat kvůli zaplnění disku — což je nejčastější tichá příčina selhání zálohování. Pracovní prostor je nutný proto, že ověření obnovy vyžaduje archiv skutečně rozbalit a načíst do dočasné databáze.

5.6 Zabezpečení záloh

Záloha obsahuje kompletní osobní údaje a autorské práce studujících. Její zabezpečení musí být proto přinejmenším na úrovni produkčního systému.

Opatření	Provedení
Šifrování v klidu	Každý archiv je zašifrován asymetricky. Server zná pouze <i>veřejný</i> klíč, kterým šifruje. Bez soukromého klíče je obsah nečitelný i pro správu školního serveru.
Úschova klíče	Soukromý klíč drží dvě nezávislé strany : technické vedení Tappky a pověřená osoba školy. Ani jedna strana nemůže data zpřístupnit ani znepřístupnit sama.
Kontrolní součty	Ke každému archivu je uložen otisk SHA-256, který umožňuje kdykoli ověřit, že soubor nebyl poškozen ani pozměněn.
Neměnitelnost	Adresář s archivy je nastaven jen pro zápis; zálohovací proces nemá právo mazat, mazání provádí oddělený proces správy retence.
Přístupová práva	Archivy jsou čitelné pouze pro určený systémový účet.
Tajemství	Přístupové údaje k Supabase jsou uloženy v souboru mimo obraz kontejneru, s právy pro čtení jen vlastníkem.

Proč dvojí úschova klíče

Rozdělení klíče mezi školu a vývojový tým řeší dvě protichůdná rizika najednou. Správa školního serveru **nemá** důvod číst eseje a reflexe studujících — šifrování jí v tom brání. Zároveň škola **nesmí** být závislá na existenci vývojového týmu — proto drží vlastní kopii klíče a data si dokáže zpřístupnit i v případě, že by spolupráce s týmem skončila.

5.7 Monitoring a ověřování obnovitelnosti

Nejběžnější způsob, jak zálohovací systém selže, není havárie — je to *tiché* přerušení běhu, které si nikdo měsíce nevšimne. Návrh proto obsahuje aktivní kontrolu:

Kontrola	Perioda	Popis
Signál o dokončení	každý běh	Po úspěšném cyklu je odeslán potvrzovací signál. Chybějící signál vyvolá upozornění — hlídá se tedy i případ, kdy se úloha vůbec nespustí.
Kontrola velikosti	každý běh	Výpisy nesmí být prázdné ani výrazně menší než minule.
Ověření otisku	měsíčně	Přepočít SHA-256 náhodně zvoleného archivu.
Zkušební obnova	čtvrtletně	Archiv se rozebalí a načte do dočasné databáze; ověří se počty záznamů a funkčnost. Výsledek se zaznamená do protokolu.
Úplné nácvikové obnovení	ročně	Postavení plně funkční kopie Tappky ze zálohy, včetně souborů.

Čtvrtletní zkušební obnova je to, co odlišuje skutečnou zálohu od souboru, o kterém se *předpokládá*, že je zálohou. Odborná doporučení uvádějí, že samotná existence archivu není důkazem obnovitelnosti — ověřením je až úspěšné načtení dat a kontrola jejich konzistence [9].

5.8 Proces vyžádání dat

Záloha má hodnotu jen tehdy, je-li dostupná ve chvíli, kdy je potřeba. Navrhujeme proto předem dohodnout následující lhůty. Bez nich hrozí, že v krizové situaci bude nutné teprve hledat, kdo má oprávnění a koho kontaktovat.

Typ žádosti	Lhůta	Popis
Havarijní obnova	do 24 hodin	Výpadek nebo ztráta dat na straně Supabase. Předání nejnovějšího bodu obnovy má absolutní prioritu; mimo pracovní dobu dle předem sjednaného kontaktu.
Předání jednoho bodu obnovy	do 2 pracovních dnů	Běžná situace — obnova omylem smazaných dat či souborů.
Předání celé sady archivů	do 5 pracovních dnů	Migrace, audit, ukončení nebo změna provozu.
Ověření existence záloh	do 2 pracovních dnů	Doložení, že zálohovací proces běží (protokol posledních běhů).

Postup

1. Vývojový tým Tappky zašle písemnou žádost pověřenému kontaktu oddělení PEVKA s uvedením požadovaného bodu obnovy a důvodu.
2. Oddělení PEVKA ověří oprávněnost žádosti a zpřístupní zašifrované archivy dohodnutým zabezpečeným kanálem (přenos v rámci školní sítě nebo předání fyzického média).
3. Příjemce ověří kontrolní součet SHA-256 a teprve poté archiv dešifruje soukromým klíčem.
4. O předání se pořídí stručný záznam — kdo, kdy, co a z jakého důvodu. Záznam slouží jako doklad o zacházení s osobními údaji.

Alternativa k procesu vyžádání

Pokud by lhůty byly z provozních důvodů problematické, lze zvolit variantu, kdy má vývojový tým **přímý přístup pro čtení** k adresáři se zálohami (například přes SFTP s omezenými právy). Archivy jsou šifrované, takže tento přístup sám o sobě nezvyšuje riziko úniku dat — pouze zkracuje reakční dobu na minuty. Volba mezi oběma variantami je na uvážení školy.

5.9 Souhrn požadavků na školu

	Oblast	Požadavek
☐	Server	Virtuální nebo fyzický stroj, Linux (doporučeno Debian 12 nebo Ubuntu 24.04 LTS)
☐	Výkon	2 vCPU, 4 GB RAM — úloha je I/O náročná, nikoli výpočetně
☐	Úložiště	1 TB dedikovaného prostoru; ideálně na jiném fyzickém poli než produkční systémy školy
☐	Software	Docker Engine (verze 24 a vyšší) s pluginem Docker Compose
☐	Sít — odchozí	TCP 443 (HTTPS) na *.supabase.co a *.supabase.com
☐	Sít — odchozí	TCP 5432 na databázový server Supabase (výpis databáze)
☐	Sít — příchozí	Žádný požadavek; služba nevystavuje žádný port
☐	Notifikace	E-mailový relay nebo webhook pro upozornění na selhání
☐	Přístup	Účet pro prvotní instalaci a čtvrtletní ověření obnovy
☐	Kontakt	Pověřená osoba oddělení PEVKA pro proces dle kap. 5.8
☐	Úschova klíče	Určení osoby, která bude držet školní kopii soukromého klíče

Zátěž serveru je nízká a soustředěná do jednoho okna v týdnu. Mimo běh zálohy je spotřeba prostředků prakticky nulová — stroj lze proto sdílet s jinými nenáročnými službami.

6 Vrstva 3 — lidsky čitelné exporty (koncept)

Vrstvy 1 a 2 chrání data v *technické* podobě. Obě předpokládají, že v okamžiku potřeby bude k dispozici někdo, kdo umí obnovit databázi a spustit aplikaci. Vrstva 3 řeší otázku, která tímto předpokladem není pokryta:

Co když je potřeba se v datech vyznat bez Tappky a bez technických znalostí?

6.1 Myšlenka

Umožnit přímo v rozhraní Tappky vyexportovat data do **běžných, čitelných formátů** — typicky jako archiv ZIP obsahující dokumenty, tabulky a nahrané soubory, uspořádané do srozumitelné adresářové struktury. Takový archiv by šlo otevřít na jakémkoli počítači, prohlédnout v běžném prohlížeči souborů a přečíst bez jakéhokoli speciálního nástroje.

Export by dal smysl pořizovat **na konci každého semestru** a archivovat spolu se zálohami vrstvy 2. Zahrnoval by texty i přiložené soubory — na rozdíl od databázového výpisu, který je sice úplný, ale bez aplikace prakticky nečitelný.

6.2 Jaké situace by řešil

- Provoz Tappky by z jakéhokoli důvodu skončil a škola potřebuje záznamy zachovat v použitelné podobě.
- Vyučující potřebuje nahlédnout do materiálů v době výpadku aplikace.
- Studující žádá o kopii vlastních dat (právo na přenositelnost údajů dle GDPR).
- Škola potřebuje doložit stav dokumentace za uzavřený akademický rok nezávisle na běžícím systému.

Stav

Vrstva 3 je v tuto chvíli **koncept**, nikoli hotová funkce. Není součástí požadavků na školu a nevyžaduje žádné rozhodnutí — je zde uvedena proto, aby byl model ochrany dat popsán celý a aby bylo zřejmé, jakým směrem se má do budoucna rozvíjet. Konkrétní podoba exportu bude předmětem samostatného návrhu.

7 Souhrnné srovnání vrstev

	Vrstva 1	Vrstva 2	Vrstva 3
	Supabase Pro	školní server	čitelné exporty
Vlastník	Supabase	Škola	Škola
Umístění	Zurich, eu-central-2	Česká republika	Dle volby školy
Frekvence	denně	týdně	semestrálně
Retence	7 dní	23 bodů obnovy (až 3 roky)	neomezená
Databáze	✓	✓	částečně
Nahrané soubory	✗	✓	✓
RPO	do 24 h	do 7 dní	do 1 semestru
RTO	desítky minut až hodiny	1–2 pracovní dny	okamžitě
Čitelné bez aplikace	✗	✗	✓
Nezávislé na dodavateli	✗	✓	✓
Náklady	součást tarifu	serverová kapacita	vývojová kapacita
Stav	✓ v provozu	předmět tohoto návrhu	koncept

RPO (*Recovery Point Objective*) — maximální množství práce, o které lze v nejhorším případě přijít, vyjádřené v čase.

RTO (*Recovery Time Objective*) — doba od rozhodnutí o obnově do okamžiku, kdy jsou data opět k dispozici.

8 Doporučený postup

#	Krok	Popis	Odpovídá
1	Projednání a schválení	Odsouhlasení alokace serveru a 1 TB prostoru	Vedení školy
2	Přidělení serveru	Zřízení stroje, instalace Dockeru, otevření odchozích portů	IT oddělení
3	Generování klíčů	Vytvoření šifrovacího páru, předání soukromého klíče oběma stranám	Tappka + škola
4	Nasazení	Nahrání konfigurace, první ruční spuštění, ověření výsledku	Tappka + IT
5	Ověření obnovy	První zkušební obnova a sepsání protokolu	Tappka
6	Předání	Předání provozní dokumentace a kontaktů	Tappka
7	Dohoda o lhůtách	Písemné potvrzení lhůt dle kap. 5.8	Škola + PE-VKA
8	Rutinní provoz	Čtvrtletní ověření obnovy, roční nácvik	Tappka

Kroky 2 až 6 představují řádově jeden až dva dny práce. Následný provoz je automatický.

A Příloha: Konfigurace služby

Následující výpisy jsou ilustrativní — ukazují rozsah a povahu konfigurace, aby si IT oddělení mohlo udělat představu o nárocích. Finální podoba vznikne při nasazení.

A.1 Definice služby (docker-compose.yml)

```
services:
  tappka-backup:
    image: ghcr.io/tappka/backup:1
    container_name: tappka-backup
    restart: unless-stopped
    env_file: /etc/tappka/backup.env
    environment:
      # Every Sunday at 02:00 UTC
      BACKUP_CRON: "0 2 * * 0"
      BUCKETS: "avatars images documents"
    volumes:
      - /srv/tappka-backup:/backup
    logging:
      driver: json-file
      options: { max-size: "10m", max-file: "5" }
```

A.2 Tajemství (/etc/tappka/backup.env, práva 0600)

```
# PostgreSQL connection string (Supabase project)
SUPABASE_DB_URL=postgresql://...

# S3-compatible endpoint for Storage buckets
RCLONE_CONFIG_SUPABASE_TYPE=s3
RCLONE_CONFIG_SUPABASE_PROVIDER=Other
RCLONE_CONFIG_SUPABASE_ENDPOINT=https://<project>.supabase.co/storage/v1/s3
RCLONE_CONFIG_SUPABASE_ACCESS_KEY_ID=...
RCLONE_CONFIG_SUPABASE_SECRET_ACCESS_KEY=...

# Public key used to encrypt archives (private key is NOT stored here)
AGE_RECIPIENT=age1...

# Monitoring: a missing ping raises an alert
HEALTHCHECK_URL=https://...
```

A.3 Zálohovací skript (zkráceně)

```
#!/bin/sh
set -eu

STAMP=$(date -u +%Y-%m-%dT%H%M%SZ)
WORK="/backup/work/${STAMP}"
OUT="/backup/archive"
mkdir -p "$WORK" "$OUT"

# --- 1. Database: roles, schema, data (three separate files) -----
supabase db dump --db-url "$SUPABASE_DB_URL" -f "$WORK/roles.sql" --role-only
supabase db dump --db-url "$SUPABASE_DB_URL" -f "$WORK/schema.sql"
supabase db dump --db-url "$SUPABASE_DB_URL" -f "$WORK/data.sql" \
  --data-only --use-copy
```

```
# --- 2. Sanity check: refuse to keep an empty or truncated dump -----
for f in roles schema data; do
    test -s "$WORK/$f.sql" || { echo "FATAL: $f.sql is empty"; exit 1; }
done

# --- 3. Storage buckets: incremental sync, changes kept as versions -----
for BUCKET in $BUCKETS; do
    rclone sync "supabase:${BUCKET}" "/backup/storage/${BUCKET}" \
        --backup-dir "/backup/storage-versions/${STAMP}/${BUCKET}" \
        --checksum --transfers 8 --retries 5
done

# --- 4. Pack, encrypt, checksum -----
tar -czf - -C "$WORK" . \
    | age -r "$AGE_RECIPIENT" -o "$OUT/tappka-db-${STAMP}.tar.gz.age"
sha256sum "$OUT/tappka-db-${STAMP}.tar.gz.age" \
    > "$OUT/tappka-db-${STAMP}.sha256"
rm -rf "$WORK"

# --- 5. Retention + heartbeat -----
/usr/local/bin/prune-gfs.sh "$OUT"
curl -fsS "$HEALTHCHECK_URL"
```

B Příloha: Manuál spuštění

1. **Příprava serveru.** Instalace Docker Engine s pluginem Compose. Vytvoření adresáře /srv/tappka-backup na svazku s 1 TB volného prostoru.
2. **Šifrovací klíč.** Vygenerování páru klíčů. Veřejný klíč se vloží do konfigurace na serveru; soukromý klíč se *na server neukládá* a předá se zabezpečeným kanálem oběma stranám, které jej drží (viz kap. 5.6).
3. **Přístupové údaje.** Vytvoření souboru /etc/tappka/backup.env s právy 0600 a vlastníkem root.
4. **Ověření sítě.** Test dostupnosti databázového serveru a koncového bodu úložiště ze serveru školy.
5. **První ruční běh.**

```
docker compose run --rm tappka-backup /usr/local/bin/backup.sh
```

6. **Kontrola výsledku.** Ověření, že v /backup/archive vznikl archiv nenulové velikosti a odpovídající soubor s kontrolním součtem.
7. **Trvalé spuštění.**

```
docker compose up -d
```

8. **Ověření monitoringu.** Záměrné vynechání jednoho běhu a kontrola, že dorazí upozornění.
9. **Zkušební obnova.** Provedení postupu z přílohy C a sepsání protokolu.

C Příloha: Postup obnovy

1. **Volba bodu obnovy.** Určení, ke kterému datu se obnovuje.

2. **Ověření neporušenosti.** Přepočet SHA-256 a porovnání s uloženým otiskem. *Neshoda znamená, že archiv nelze použít — pokračuje se předchozím bodem obnovy.*
3. **Dešifrování** soukromým klíčem a rozbalení archivu.
4. **Obnova databáze** v pořadí `roles.sql` → `schema.sql` → `data.sql`.
5. **Obnova souborů** nahráním zrcadla kontejnerů `avatars`, `images` a `documents` zpět do úložiště.
6. **Kontrola konzistence.** Porovnání počtu záznamů, namátková kontrola, že odkazy na soubory vedou na existující objekty.
7. **Ruční kroky po obnově.** Obnovení hesel vlastních databázových rolí a případných replikačních odběrů — ty nejsou součástí výpisu.
8. **Funkční ověření.** Přihlášení do aplikace, otevření eseje s přílohou, zobrazení profilové fotografie.
9. **Protokol.** Zaznamenání data, použitého bodu obnovy, doby trvání a zjištěných odchylek.

D Zdroje

Všechny odkazy ověřeny k 31. 8. 2026.

Reference

- [1] SUPABASE. *Database Backups*. Oficiální dokumentace.
<https://supabase.com/docs/guides/platform/backups>
Doloženo: retence 7 dní denních záloh v tarifu Pro; fyzické zálohy; zálohy nezahrnují objekty uložené přes Storage API; nedostupnost projektu po dobu obnovy.
- [2] SUPABASE. *Pricing*.
<https://supabase.com/pricing>
Doloženo: obsah tarifu Pro — 8 GB diskového prostoru databáze, 100 GB prostoru pro soubory, 7denní retence logů, denní zálohy po 7 dní, absence SLA, SOC 2, ISO 27001 a SSO.
- [3] SUPABASE. *Shared Responsibility Model*.
<https://supabase.com/docs/guides/deployment/shared-responsibility-model>
Doloženo: rozdělení odpovědnosti mezi Supabase a provozovatele aplikace; citovaná věta o minimu zábran kolem databáze.
- [4] SUPABASE. *SOC 2 Compliance and Supabase*.
<https://supabase.com/docs/guides/security/soc-2-compliance>
Doloženo: Supabase je SOC 2 Type 2 compliant a je každoročně auditována; auditní zpráva je dostupná pouze v tarifech Team a Enterprise.
- [5] SUPABASE. *Production Checklist*.
<https://supabase.com/docs/guides/platform/going-into-prod>
Doloženo: dostupnost vynucení TLS, síťových omezení, RLS, vícefaktorového ověření a omezení četnosti požadavků.
- [6] SUPABASE. *Automated backups using GitHub Actions*.
<https://supabase.com/docs/guides/deployment/ci/backups>
Doloženo: doporučený postup výpisu do tří souborů (`roles.sql`, `schema.sql`, `data.sql`) včetně přepínačů `-role-only`, `-data-only` a `-use-copy`.
- [7] SUPABASE. *S3 Compatibility*.
<https://supabase.com/docs/guides/storage/s3/compatibility>
Doloženo: úložiště souborů zpřístupňuje rozhraní kompatibilní s S3 na koncovém bodu `/storage/v1/s3`, použitelné standardními nástroji.
- [8] FEDERÁLNÍ ÚŘAD PRO OCHRANU ÚDAJŮ A TRANSPARENTNOST (EDÖB, ŠVÝCARSKO). *EU adequacy decision regarding Switzerland*, 15. 1. 2024.
<https://www.edoeb.admin.ch/en/15012024-eu-adequacy-decision-regarding-switzerland>
Doloženo: Evropská komise potvrdila dne 15. 1. 2024 odpovídající úroveň ochrany osobních údajů ve Švýcarsku; přenos z EU/EHP je možný bez dodatečných záruk.
- [9] PŘEHLED ODBORNÝCH DOPORUČENÍ K PRAVIDLU 3–2–1 (Veeam, Commvault, Object First).
<https://www.veeam.com/blog/321-backup-rule.html>
Doloženo: pravidlo 3–2–1 jako základní standard doporučovaný CISA a NIST; rozšíření 3–2–1–1–0 o neměnitelnou kopii a ověřované obnovy; nutnost testovat obnovu na úrovni aplikace, nikoli pouze existenci archivu.